

Changelog — ARMP-2026.07.21-PILOT-AUTH-R3

Added

- **Supabase control plane:** organizations, profiles, memberships, pilot_entitlements, invitations, internal_role_assignments, security_events, activation_events, admin_action_requests (12 migrations).
- **Row-Level Security** on every protected table; default-deny; internal_notes column revoked from client roles; all mutations via service-role Edge Functions only.
- **20 Edge Functions** for privileged operations (org/pilot lifecycle, invitations, user lifecycle, dual-control MFA reset, dashboard, authorize-pilot-session, bootstrap-first-owner).
- **Mandatory TOTP MFA** (AAL2) for pilot users and the Operations Console.
- **Auth pages:** invite, callback, setup-mfa (QR + manual key), challenge-mfa, reset-password.
- **Server-backed app authorization** (ARMP_AUTH): authorize-pilot-session before any real-data workflow; 300s revalidation upper bound; server clock authoritative.
- **Operations Console** rebuilt on Supabase session + AAL2 + active internal role; Organizations/Users/Invitations/Activity views.
- New test suites: frontend-security, data-boundary (network-instrumented), R2-migration; expanded prohibited-pattern gate; local RLS suite.
- Approval-gated CI workflows for staging migrate/deploy/test.

Removed

- **R2 format-only pilot code** (ARMP-PILOT-XXXX-XXXX regex, isValidPilotCode , login/registration pilot-code paths, the license input field). Self-registration now opens Demo Mode only.
- Legacy Google-domain-only Operations Console gate (email domain alone grants nothing now).

Unchanged / preserved

- Local financial-data boundary: customer files never leave the browser during the core workflow; Supabase receives control-plane traffic only.
- R2 matching engine and its 503 assertions (retained, unweakened).
- ACH/wire commercial model; no Stripe anywhere; documented LIMITS (no unlimited).